

DEN/CYBER-EUSR-0010: Cybersecurity requirements for security information and event management (SIEM) systems

Deep Dive Session

Presented by:

August Bournique and Santeri Toikka
Bow Shock Consulting

EN 304 622

22/01/2026

Agenda

Refresher on CRA Standards

Focus on SIEM Vertical

The Shared Approach to CRA Verticals

The Structure of the SIEM Standard

- Example – Risk Factors

- Example – Security Requirements and Mitigations

- Example – Testing

Remote Data Processing

A Refresher on the CRA Standards

Cyber Resilience Act Purpose

- Regulates the safety of most software and hardware **Products with Digital Elements** placed on EU market.
- Improves security and transparency of products for EU consumers.

The Cyber Resilience Act Goals

- Reporting obligations begin **September 2026**.
- Full Compliance and Product Assessment by **December 2027**.

Standardization Process

- European Commission request to ESOs (including ETSI) to draft standards covering **essential security requirements** for select market segment.
- Standards are beneficial but optional way to self-assess important products.
- If harmonized, standards provide **presumption of conformity**, shifting legal burden of proof for manufacturers.

SIEM Vertical Focus

SIEM as a Product

- Scope is limited by CRA and EC definition (below).
- Excludes SOAR and many functions that are often bundled by SIEM products, but standard is still useful for components of aggregate products.
- SIEM is particularly dependent on Remote Data Processing Solutions (RDPS).

Current Definition of SIEM:

“Products with digital elements that collect data from multiple sources (including at least from network elements), analyse and correlate that data and present it as actionable information for security-related purposes, such as threat and incident detection, forensic analysis or compliance purposes.”

Shared Approach to CRA Vertical Standards

Process for Using Vertical Standards

- Manufacturer chooses product's **intended use**
- Product centered **risk assessment** of threats based on **intended use** and **foreseeable uses**
- Foreseeable misuse must be addressed via **risk transfer** or covered by security requirements.
- Risk assessment determines **risk factors** and level (low, med, high)
- **Risk factors** are individually linked to **security requirements** with various technical and documentary **mitigations**
- Specific **mitigations** based on risk level of each **risk factor** can be fulfilled by tests or other requirements
- Some risks factors and mitigations may be modified by factors of product's overall risk, intended deployments environment, intended users, or other product elements (e.g. RDPS)

Structure of SIEM Standard

1. Scope
2. References
3. Definitions
4. Product Context (Architecture, Risk Factors, Use Cases)
5. Requirement Specifications (Including Mitigations)
6. Conformity Assessment (Including Tests)

Annex A. Mapping with essential requirements of the CRA

Annex B. Relationship to any related ETSI standard

Annex C. Risk Assessment Criteria

Note: Additional Annexes in process to provide for “cross-vertical” topics such as Secure Updates and RDPS requirements.

Example: Risk Factors

4.5.1.3 Security expectations of the deployment context [NIS 2]

The sum of likelihood and impact based on the intended deployment context, purpose of the product. Reference to NIS 2 status of product context

- **Low Risk**
NIS2 status is undefined;
The intended deployment target is a household or a small business.
- **Medium Risk:**
NIS2 status is undefined;
The product serves a larger audience;
The managed element is widely used.
- **High Risk::**
The product is targeted to NIS2 important or essential entities.

Example: Security Requirements and Mitigations

5.3.8 Mitigations for High Availability (Low Risk)

Risk level based on [NIS 2] and other factors.

High availability is the reliability of running processes and risk of loss of underlying resources. Administrative actions can shutdown the node without prior announcement. Product software must be designed to tolerate interruptions. Depending on the implementation and runtime context, a singular process, when implemented correctly, can also provide the targeted service availability and a self healing system can expeditiously launch a replacement

For Low Risk:

[REQ-HA-0] Expected availability shall be defined for each relevant system component.

[REQ-HA-1] System updates and changes shall be included in the availability time definition.

Example: Testing

6.3.8 High availability tests

6.3.8.0 REQ-HA-0

- **Requirement:**
Expected availability shall be defined for each relevant system component.
- **Objective and Preparation:**
Have the product initialized and available with the default configuration and required credentials.
- **Activities:**
Study the metrics for availability information.
- **Verdict:**
Pass all relevant components availability is defined and tracked; Fail otherwise.
- **Supporting Evidence:** Relevant metrics described in the technical documentation.
Screenshots of metrics being visualized in the dashboards.

RDPS Approach

CRA Definition - Article 3, 2

*“[D]ata processing at a distance for which the software is designed and developed by the manufacturer, or under the **responsibility** of the manufacturer, and the absence of which would prevent the product with digital elements from performing one of its **functions**.”*

- **Intrinsic and Extrinsic Risks of RDPS**

Intrinsic Risk is the risk related to the remote nature of the RDPS, Extrinsic Risks are the risk of the function itself.

- **5.2.7 RDPS Risk Factor for Intrinsic Risk**

Numerous Requirements and Mitigations focused on use of RDPS found in this Risk Factor, otherwise RDPS is treated as any other Risk Factor.

- **Other Remote Service Risks Treated as Component or Standard Specific Function**

Awaiting EC guidance of Due Diligence specifics.

Note: RDPS risks may be moved to Annex

Q&A



Feel free to contact me:

Contact:
august@bourniquelaw.com

Follow us on:   